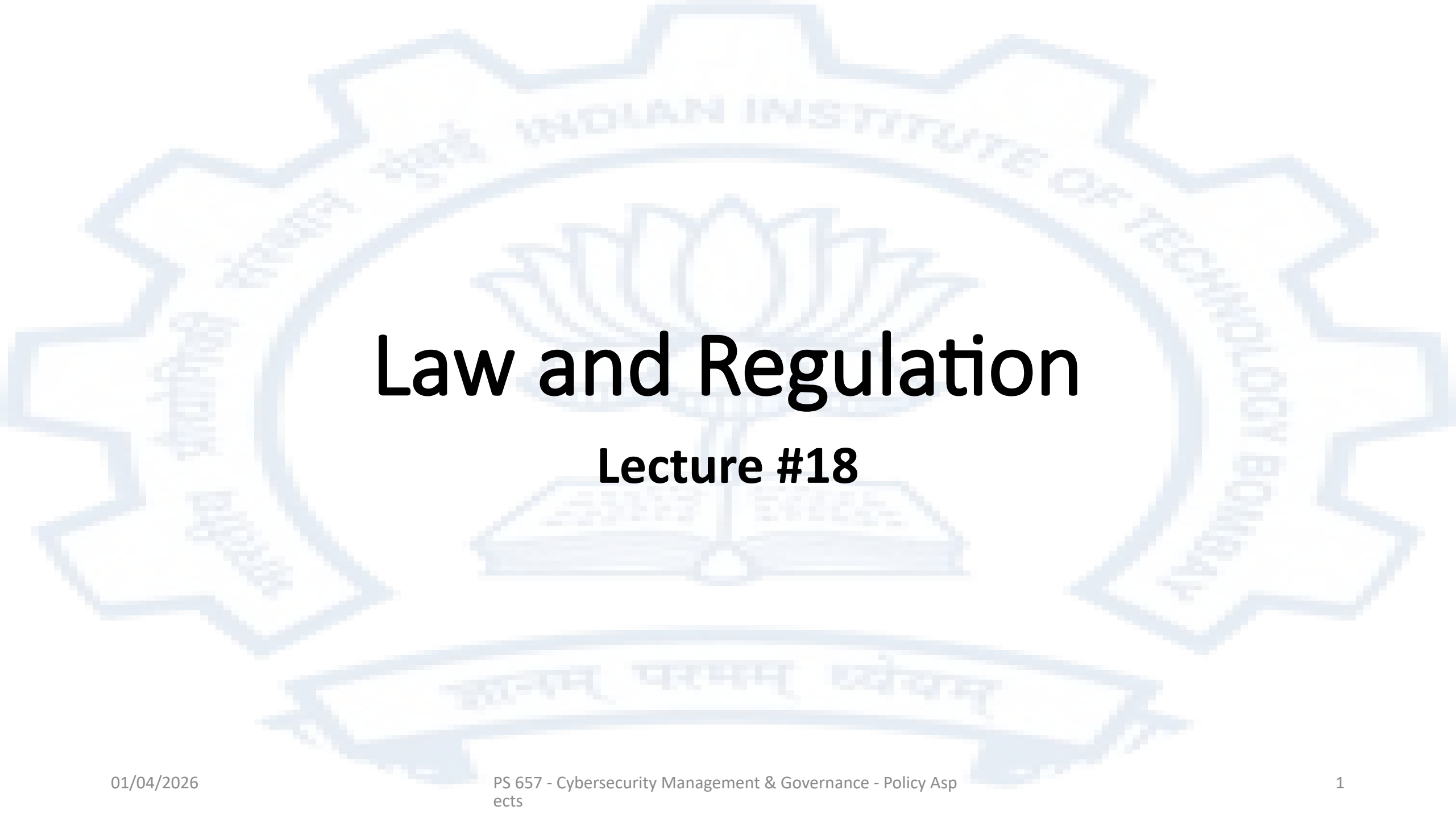




Law and Regulation

Lecture #18

Law and the sciences

- The rules of mathematics and the physical sciences are fixed and immutable across the world
- The rules of law are not fixed and nor are they uniform all over the world
- One of the most basic foundations of traditional law is the concept of jurisdiction based upon territorial sovereignty
 - Practically this may mean that something may be allowed in one country but not allowed in another
 - These differences are not erased just because people are acting with the instrumentality of cyberspace

The nature of law

- The law should be analysed with rigorous logic just as matters in the scientific sphere are
- The purpose of science is conceptualized as discovering the immutable principles of nature whereas the purpose of law is concerned with society, social and political values, human desire and human frailty
- There are three aspects to law
 - Making laws (legislative authority)
 - Interpreting laws (judicial authority)
 - Enforcing laws (executive authority)

Legal analysis

- As with scientific analysis, legal studies and analysis aim to predict outcomes
 - In Chemistry the scientist predicts what will happen if two substances are brought into contact in specific conditions
 - In law the legal theorist attempts to predict the outcome of a dispute placed before an appropriate legal forum
- The law itself may consist of
 - Primary legislation
 - Secondary legislation (sometimes called regulations)
 - Codes
 - Judicial decisions

Applying law to cyberspace and information technologies

There are two major schools of thought

- One school holds that cyberspace was radically different to anything in human experience. Therefore they argued that old laws were widely inapplicable. Some more radical thinkers advocate a denial of sovereign states right to enact legislation and regulations in respect of Internet activity – The “Cyberspace is Lawless” approach
- The second school holds that the Internet is just another technical instrumentality that humans have invented. Therefore all existing rules and regulations should continue to be applicable even while using the instrumentality of the Internet. This school rejects the idea that cyberspace is a legal jurisdiction different from real space – The “Cyberspace is an intersection of jurisdictions” approach

So far mostly the second school has prevailed

Criminal law- purpose

- Criminal law is the body of law that prohibits behaviour generally abhorred by society. Criminal law is normally enforced by an agency of the state. Breaches of criminal law are prosecuted by the state and not the victim.
- The purposes of criminal law are usually described as some combination of:
 - deterrence (seeking to deter bad behaviour, for both members of society generally and a criminal specifically);
 - incapacitation (limiting the ability of the criminal to further harm society);
 - retribution (causing a criminal to suffer some type of loss in response to crime);
 - restitution (causing a criminal to compensate a victim or some related person);
 - rehabilitation (seeking to change the long-term behaviour of a criminal).

Criminal law – awareness, intent and punishments

- There is often no requirement for an accused to have understood that their actions were defined as criminal
- States normally must prove that the accused intended to take those actions and reasonably understands the consequences of those actions
- Punishments available in criminal law include custodial prison sentences, criminal fines normally remitted to the state, seizure and forfeiture of criminal proceeds, and financial or other restitution remitted to victims. Some jurisdictions also apply corporal punishment and sometimes execution
- Terms such as ‘guilty’ and ‘innocent’ are normally reserved as descriptions of verdicts in a criminal case. These terms should not be used when referring to outcomes of civil actions.

Civil law- purpose

- Civil law is the body of law that regulates relationships between people. Examples include the law of contracts and laws about negligence. A person aggrieved by a breach of these laws can bring action against the person in breach.
- Civil law is often designed to redress negative externalities in a modern economy.
 - Poor security in ICT products and services is a stark reality that causes significant negative externality that often falls short of criminality
- Policy makers hope that people who become aware that certain type of risk-taking carry an associated liability for resulting harm will alter their behaviour for the better

Civil law- remedies

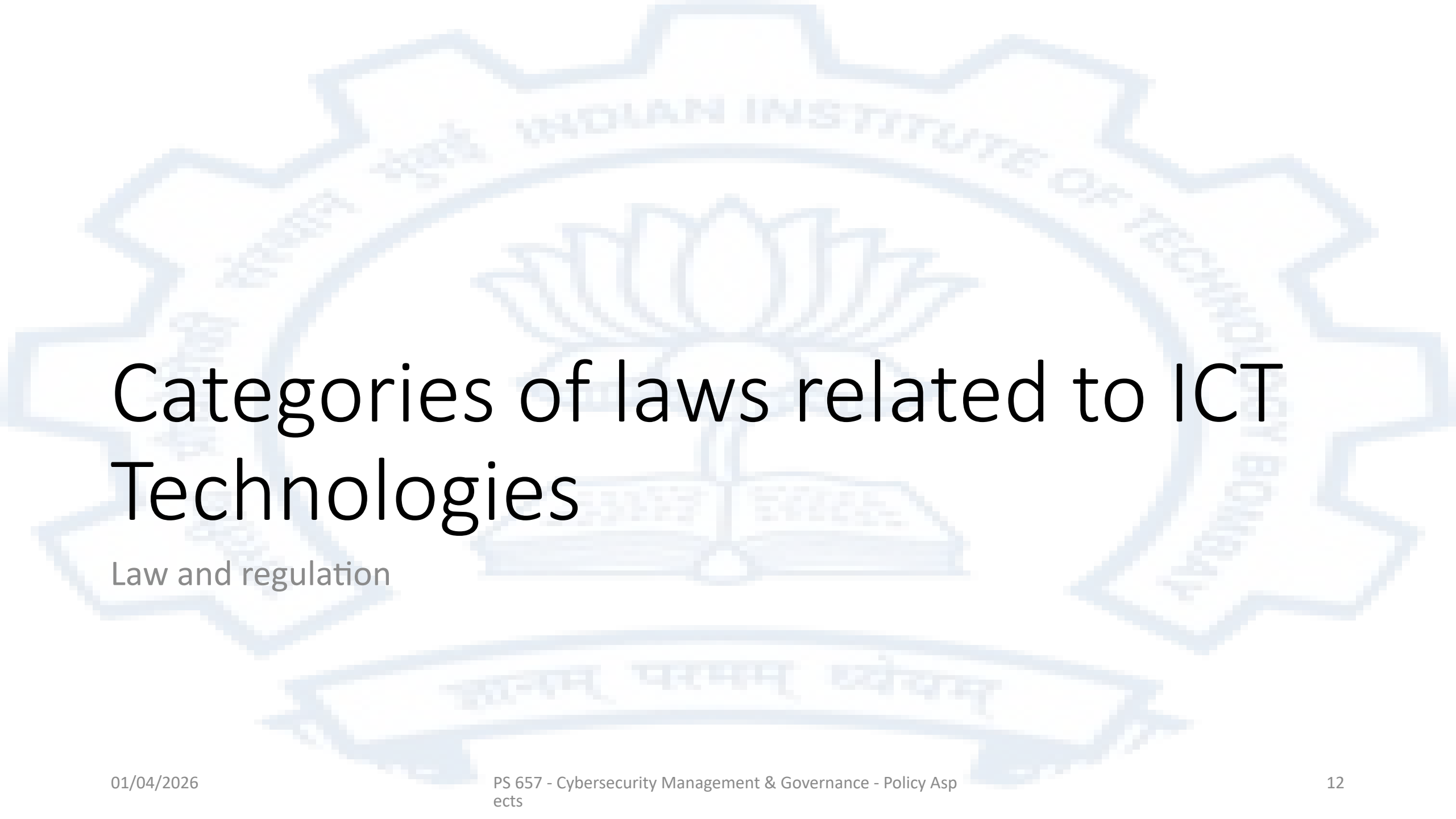
- Remedies available under civil law (depending on the circumstances) may include some combination of:
 - an order for the liable party to pay compensation to the injured party;
 - an order to terminate some legal relationship between the parties;
 - an order for the liable party to discontinue harmful activity; or
 - an order for the liable party to take some type of affirmative act (e.g., transferring ownership of property).

Evidence and proof

- The concept of proof in law is different from the concept of proof in mathematics and logic. This sometimes causes confusion in discussions of cyber security topics and the law
- In law to prove something simply means to use permissible evidence in an effort to demonstrate the truth of contested events to a fact finder to a prescribed degree of certainty
- Permissible evidence can take a variety of forms. Subject to the rules of different legal systems, evidence might include direct witness testimony, business records, correspondence, surveillance records, recordings of intercepted telephone conversations, server logs, etc.

Standards for degree of certainty

Standard of proof	Degree of Certainty Required	Example context
Beyond a reasonable doubt.	Extremely high. Almost incontrovertible. No other reasonable explanation exists to make sense of the evidence.	States are most often required to meet this, or a similar standard, in proving the elements of a crime for a fact finder to hold an accused person guilty. This higher standard is heavily influenced by notions of human rights law because individual life and liberty are at stake.
Clear and convincing evidence.	Reasonably high certainty. Much more than simply 'probable'.	This standard of proof is used in US law, for example, when a court is asked to invalidate a previously granted patent. The burden of proof placed upon the person seeking to invalidate the patent is set high because this would deprive a rights-holder of property previously granted by the patent office. This phrase is also used to describe the standard to be met by prisoners who challenge the validity of their criminal conviction in US federal courts using a <i>habeas corpus</i> petition long after normal routes of appeal have been exhausted. In this circumstance, the higher standard is required as a means of preserving the integrity of the original criminal justice process (including the original appeals) while not foreclosing all possibility of post-conviction review.³⁷
Preponderance of evidence.	More probable than not.	The most common formulations of the standard of proof required to prevail in a civil case.
Balance of probabilities.	Greater than 50%. When weighed on the scales of justice, the evidence on one side is at least a feather-weight greater than the other.	
Probable cause.	The evidence suggests that the target of an investigation has committed a crime, although evidence is not yet conclusive.	The standard required in the US to persuade a judicial officer to issue a search warrant or arrest warrant. This standard serves to filter out trivial or unsubstantiated requests to intrude into privacy or detain a suspect.
Reasonable suspicion.		The standard typically required in the US to justify a police officer temporarily stopping and questioning a person. This lower standard is often justified on policy grounds of minimising threats to the safety of police officers. This phrase has also been suggested by the United Nations High Commissioner for Human Rights on the right to privacy in the digital age as a threshold for justifying state electronic surveillance [89].



Categories of laws related to ICT Technologies

Law and regulation

Privacy laws and electronic interception

Broadly such laws cover

- The right to privacy as a human right and limitations on privacy
- Interception by a state
- Interception by persons other than states
- Penalties and enforcement

Data Protection- framework

Broadly such laws cover

- Basic concepts
 - Personal data, data principal
 - Processing
 - Consent
 - Controller and processor
- Appropriate security measures
- Assessment and design of processing systems
- Personal data breach and notification
- Enforcement and penalties

Data Protection – International data transfer

Most data protection laws addresses cross-jurisdiction data transfer in some way. The aspects covered are

- Adequacy determinations
 - This is aimed at determining if a receiving territory has adequate protections
- Transfers subject to safeguards
- Transfers subject to mutual legal assistance treaties (MLATs)
- Derogations allowing transfers – for example
 - Informed consent
 - Contract performance
 - Public interest
 - Pursuance of a legal claim
 - Life or welfare of a person unable to consent

Cybercrime

This is used to refer to three types of criminal activity

- Conventional crimes where cyberspace or computers are just an instrumentality – i.e. financial fraud
- The distribution of prohibited content – i.e. obscene material, hate speech
- Crimes against computers and computer infrastructure

Crimes against computers and information systems

- Improper access to a system
- Improper interference with data
- Improper interference with systems
- Improper interception of communications
- Producing hacking tools with improper intentions

Contracts

- The term 'contract' describes a (notionally) volitional legal relationship between two or more persons
- Parties to a contract may agree to certain conditions and penalties for failure to fulfil those conditions even if there is no law requiring those conditions to be met
- In the context of cybersecurity, legislation is often lagging and is ambiguous in many material details. In such situations parties may bring obligations by the method of contracts
- Contracts can serve as a mechanism to encourage the use of security standards even if the laws of a country do not yet cover material aspects
- Contracts are also used to offer or exclude warranties
- Contracts are also used to limit or exclude liability

The law of torts – as applied to IT based products and services

- A tort is any civil wrong other than a breach of contract. Unlike contractual liability, tort liability is not necessarily predicated upon a volitional relationship between the person who commits a tort (a 'tortfeasor') and the person harmed by that tortious action (a 'victim').
- Types of liability
 - Negligence
 - Duty of care
 - Breach of duty
 - Product liability
 - Strict liability
- Quantum of liability
- Attributing liability
 - Direct liability
 - Vicarious liability
 - Joint and several liability

When this potential tortfeasor:	Conducts this activity in an unreasonable manner:	Consider whether the potential tortfeasor owes a duty of care to these potential victims:
Retail merchant	Maintaining security of payment card details supplied by customers at point of sale.	Card holders; Merchant banks; Card issuing banks. [198]
Email service provider.	Managing the security of email servers and related services; Making decisions about the types of security to be adopted.	Service subscribers; Subscribers' third-party email correspondents; Persons named in email correspondence.
Business enterprise.	Managing the cyber security of enterprise IT or OT; Making decisions about the types of security to be adopted.	Its own staff members; [199] ¹²¹ Its counter-parties and supply chain partners; Unrelated third parties suffering harm when malicious actors compromise the enterprise's security measures and use the enterprise's IT to launch onward attacks; Unrelated third parties who suffer harm when compromised OT causes personal injury or property damage.
Developer of web server software.	Implementing standard cryptographic communication protocols.	Merchants that adopt the web server software for online commerce; SaaS providers that adopt the web server software for the provision of various services to customers; Customers submitting payment card details; Business customers that submit sensitive business data to a SaaS provider that adopted the server software; Business enterprises that adopt the server within their IT or OT infrastructure.
Trust service provider. ¹²²	Registering the identity to be bound to a certificate; Issuing certificates; Maintaining the trust infrastructure.	Customers who purchase certificates; Third parties who place reliance on these certificates; Third parties who operate equipment which (without their knowledge) places reliance on these certificates.
Web browser developer.	Selects root trust certificates for installation into its web browser.	Natural persons who use the web browser.

Table 3.2: Illustration of potential duty of care relationships

Intellectual property

- Copyrights

- Copyright is an unregistered right that springs into existence on the creation of a sufficiently original work. Copyright subject matter includes literary works, which for this purpose includes software code (both source and executable code).

- Patents

- A patent is a registered intellectual property right, granted on a state-by-state basis following application and examination. Patents are meant to protect an invention that is novel and that also includes an additional distinguishing characteristic variously described by states as an 'inventive step', a 'non-obvious' character, or something similar.
 - Cyber security-related inventions that appear on their face to be purely mathematical or algorithmic (e.g., cryptographic methods) can be the subject of patent protection as embodied in various devices – including software-enabled devices. Aspects of historically significant cryptography inventions have been protected by patents, including DES, Diffie-Helman, and RSA. Although the patents on these breakthrough cryptographic inventions have now expired, the field of cyber security innovation remains awash with patents and pending patent applications

- Trademarks

- Trademarks are usually registered intellectual property rights, granted on a state-by-state basis following application. A trademark is a symbol or sign used to distinguish one person's business or products from another's. The most common trademarks consist either of words or figures.

- Trade secrets

- Trade secrets were traditionally protected under general tort law, giving persons who attempted to keep their secrets the right to take legal action against those who inappropriately obtained, used or disclosed these secrets. Unfortunately, loss of trade secrets through acts of cyber industrial espionage is believed to be widespread and should be a source of major concern for cyber security practitioners

Reverse engineering

- Could be considered as the flip-side of trade secrets.
 - The misappropriation of trade secrets through espionage has traditionally been prohibited by law
 - However the scientific study of a device sold and purchased in a public sale in an effort to learn its secrets has generally been viewed as 'fair game'. If a trade secret is successfully reverse engineered in this fashion and published, it ceases to be a trade secret.
- In recent years there is a shift in the legal treatment of reverse engineering following the adoption on anticircumvention mechanisms. In the specific case of software, licensing conditions prohibit reverse engineering in general and reverse compilation in specific

Testing proprietary crypto algorithms

- Security researchers hoping to test the strength of a cryptographic system normally require access to the relevant algorithm. This arises naturally from Kerckhoffs's Principle and is well-known to cryptographers. A person who wishes to test the security capabilities of an algorithm encounters practical difficulties when the manufacturer of the product employs a proprietary algorithm protected by trade secret and does not wish to disclose it for testing.
- In the *Megamos Crypto* case (*Volkswagen v Garcia*), the cryptographic product under examination (a special purpose processor chip used in automobile engine immobilisers and keys) was manufactured under license by the algorithm's developer. The testers (academic researchers) did not reverse engineer this product, which could have been accomplished using an expensive chip slicing technique. They chose instead to recover the algorithm by reverse engineering third-party software (Tango Programmer) that implemented the Megamos algorithm
- The researchers intended to publish the results of their analysis, which would have disclosed the algorithm. Parties who had an interest in the trade secret status of the algorithm brought legal action in the English courts to halt publication. The English high court was confronted with a request to prohibit publication of the research pending a full trial on the merits. The court seemed to accept that if the researchers had recovered the algorithm from the product itself using the chip slicing technique, there would be no case to answer. But the court found that there was a possibility that the third-party Tango Programmer software may have existed only as a result of trade secret misappropriation, and that the researchers should have been aware of this

Dematerialization of documents and electronic trust services

The aspects covered broadly are

- Admission into evidence for electronic documents
- Requirements of form and the threat of unenforceability
 - certain legal notices must be delivered 'in writing';
 - certain types of commitment must be in writing and 'signed' by (or 'executed under the hand of', etc.) the party against whom enforcement is sought;
 - certain submissions to a state agency must be made using a specified form;
- Electronic signatures and identity trust services

Ethics

- Obligations owed to a client
- Codes of conduct
- Vulnerability Management
 - Testing for vulnerabilities
 - Disclosure of vulnerabilities
- Facilitating and acting on vulnerability disclosures

International law

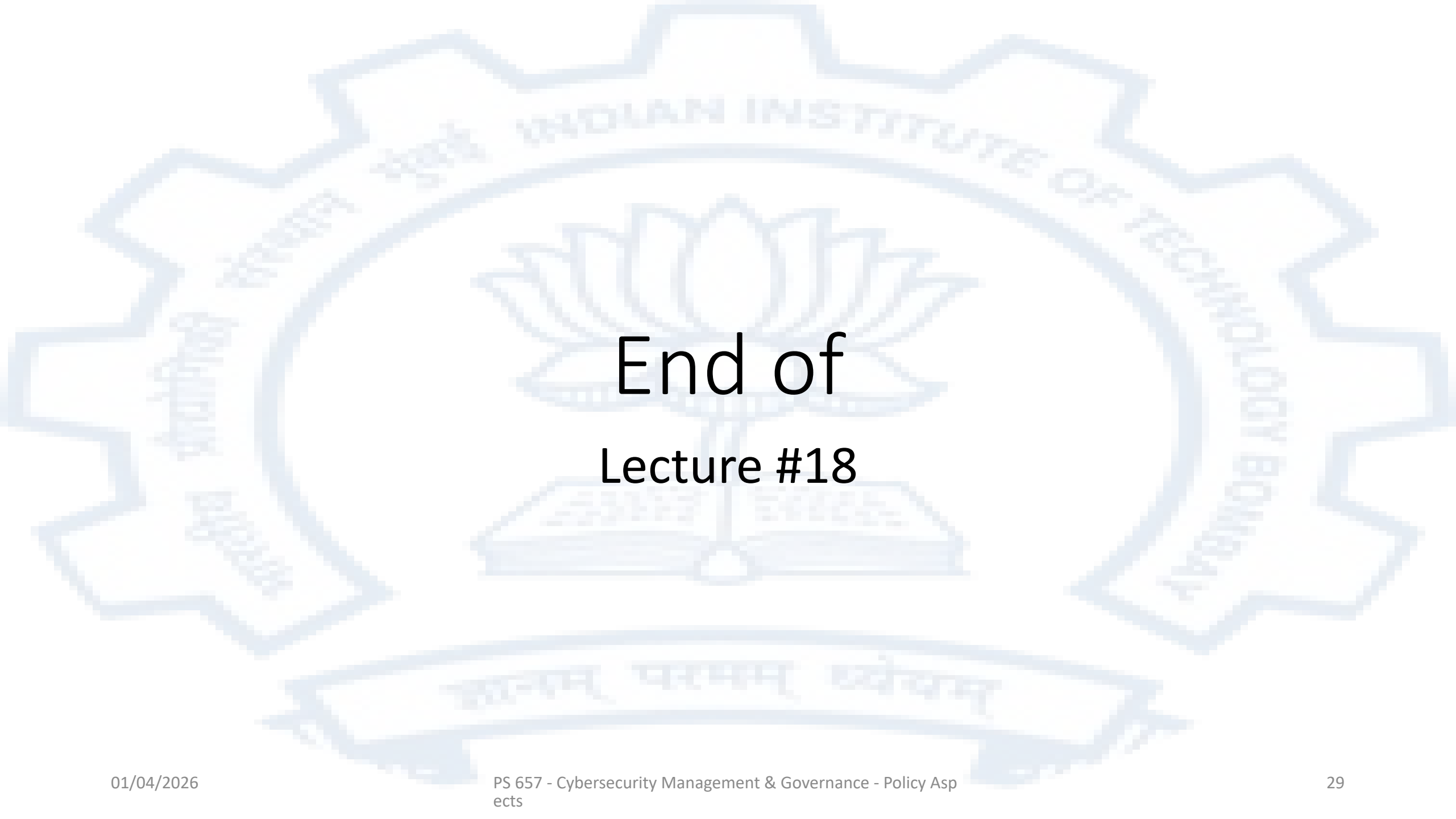
- Attributing action to state under international law
- State cyber operations in general
- Cyber espionage in peacetime
- Cross-border criminal investigation
- The law of armed conflict

The Indian landscape

- IT Act 2000 amended in 2008
 - The IT Act was mainly about authenticating documents in electronic form
 - The original act did describe computer misuse and criminalize some types of activity
 - The 2008 amendment expanded and clarified the computer misuse and criminal provisions
- The Digital Personal Data Protection Act 2023
 - Focusses on the protection of personal digital data
- The Aadhaar Act 2016
- There have been minor amendments to other laws mainly to give effect to the IT Act and DPDPA but also in response to the increasingly digital environment
- The incompleteness of legislation/regulation and the pendency in the Indian courts appears to have discouraged litigation in the digital areas as compared to other areas

To summarize

- There are two main branches of law
 - Criminal
 - Civil
- The development of information and communication technology have produced hitherto unseen challenges
- The nature of ICT technologies requires emphasis on security but there may be insufficient incentives to implement effective cybersecurity
- Many jurisdictions have responded by developing several laws and regulations covering topics such as privacy, data protection, computer misuse, cybercrime, intellectual property etc
- The cross border nature of digital technologies has resulted in the formation and updation of a significant body of international law



End of Lecture #18